Gobierno de la Ciberseguridad y Análisis de Riesgos

Tema 8. Metodologías de análisis de riesgos

Índice

Esquema

Ideas clave

8.1 Introducción y objetivos

8.2. Magerit

8.3. ISO/IEC 27005:2018

8.4. NIST 800-30 Rev. 1

8.5. Referencias bibliográficas

Test

A fondo

Análisis de Magerit y PILAR

Artículo de revisión de Metodologías de Análisis de Riesgos de la Información, enfocado a Pymes

Gestión del riesgo de TI con base en la norma ISO 27005:2011, adaptando la metodología NIS SP 800-30

Gestión de riesgos de seguridad. (2009). Análisis de modelos según NIST SP 800-30" y la norma ISO/IEC 27005:2008

Gestión de riesgos. Magerit

Esquema



© Universidad Internacional de La Rioja (UNIR)

8.1 Introducción y objetivos

El objetivo fundamental de este tema es conocer y analizar algunas de las metodologías de análisis y gestión de riesgos de uso más generalizado.

Los principales objetivos de este tema son los siguientes:

- Conocer distintas metodologías sobre análisis y gestión del riesgo.
- Identificar la metodología de análisis y gestión del riesgo que más se adecúe a una organización.
- Conocer distintos enfoques para el análisis y gestión del riesgo.

A la hora de abordar un proceso de gestión y análisis de riesgos es necesario elegir una metodología y una herramienta que la soporte.

La metodología que se escoja debe ser objetiva, fiable, medible y replicable, además, debe permitir la medición continua y estar soportada por una herramienta de gestión.

Sus resultados deben ser entendibles por la dirección y permitir dar respuesta a cuestiones como las siguientes:

- ¿Cuál es el nivel de riesgo al que va a estar expuesta una organización al poner en producción una nueva aplicación que da soporte a una función de negocio vital para la organización?
- ¿Cómo aumenta el nivel de riesgo en el momento que cae una de las aplicaciones, tal y como reflejan las alarmas de los sistemas de monitorización?
- ¿El nivel de riesgo al que está expuesta una organización es el adecuado de acuerdo con el sector de mercado al que pertenece la organización?
- ¿Cómo se recalcula el riesgo cuando es descubierta una nueva amenaza?

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

Con la finalidad de alcanzar los objetivos propuestos, en este tema se analizarán tres de las metodologías de gestión de riesgos más utilizadas:

- Magerit.
- ISO/IEC 27005:2011.
- NIST 800-30 Rev. 1.

© Universidad Internacional de La Rioja (UNIR)

8.2. Magerit

Magerit es una metodología de carácter público, desarrollada por el Ministerio de Administraciones Públicas (MAP) y para su utilización no se requiere la autorización previa. Este programa es de interés para todos aquellos que trabajan con información y los sistemas informáticos que la tratan.

Magerit implementa el **proceso de gestión de riesgos** dentro de un marco de trabajo para que los órganos de gobierno tomen decisiones teniendo en cuenta los riesgos derivados **del uso de tecnologías de la información.**

A su vez, en al ámbito de Magerit se define **'seguridad'** como la capacidad de las redes o de los sistemas de información para **resistir,** con un determinado nivel de confianza, los accidentes o acciones ilícitas o malintencionadas que comprometan la disponibilidad, autenticidad, integridad y confidencialidad de los datos almacenados o transmitidos y de los servicios que dichas redes y sistemas ofrecen o hacen accesibles (Dirección General de Modernización Administrativa, Procedimientos e Impulso de la Administración Electrónica, 2012).

A la hora de llevar a cabo un proyecto de análisis y gestión de riesgos de acuerdo con Magerit se debe proceder con las siguientes **tres fases:**

- Planificación del proyecto.
- Análisis de riesgos.
- Gestión de riesgos.

A continuación, vamos a introducir la segunda y tercera de estas fases, que son las que tratan directamente con los **riesgos asociados a proyectos.**

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

La metodología Magerit define **'riesgo'** como la estimación del grado de **exposición a una amenaza** para que se materialice sobre uno o más activos que pueda causar daños o perjuicios a la organización. Es decir, el riesgo indica lo que le podría pasar a los activos si no se protegieran adecuadamente. Es importante saber qué características son de interés en cada activo, así como saber en qué medida estas características están en peligro, es decir, **analizar el sistema** o, en otras palabras, el análisis de riesgos (Dirección General de Modernización Administrativa, Procedimientos e Impulso de la Administración Electrónica, 2012).

El **análisis de riesgos** es el **proceso sistemático** para estimar la magnitud de los riesgos a que está expuesta una organización. Mediante este análisis se trata de saber lo que podría pasar, para que esta información ayude a las personas adecuadas en la toma de decisiones.

Además del análisis de riesgos, encontramos el **tratamiento de los riesgos,** que sería el proceso destinado a modificar el riesgo. Entre las formas de tratar un riesgo encontramos por ejemplo evitar las circunstancias que lo provocan, **reducir las posibilidades** de que ocurra, **acotar sus consecuencias,** compartirlo con otra organización (típicamente contratando un servicio o un seguro de cobertura).

Ambas actividades, análisis y tratamiento, se combinan en el proceso denominado gestión de riesgos de la metodología Magerit.

La metodología Magerit está alineada con la UNE-ISO 31000 y su proceso de gestión de riesgos contempla las siguientes actividades.

© Universidad Internacional de La Rioja (UNIR)

Actividades del proceso global de gestión del riesgo según Magerit

Magerit establece las siguientes actividades para el proceso global de gestión de riesgos:

- Determinación del contexto.
- Identificación de los riesgos.
- Análisis de los riesgos.
- Valoración de los riesgos.
- Tratamiento de los riesgos.
- Comunicación y consulta.

A continuación, se describen brevemente.

Determinación del contexto

Es necesario conocer los parámetros y condicionantes externos e internos que nos van a permitir establecer los criterios que se van a seguir a la hora de gestionar los riesgos. Un elemento importante que destacar es el alcance del análisis, incluyendo las obligaciones legales propias y los compromisos contractuales, así como las relaciones con otras organizaciones.

Identificación de los riesgos

Se elabora una relación de los posibles riesgos a los que está expuesta la organización. Lo que se identifique será analizado en la siguiente etapa. El riesgo que no se identifique no se tendrá en cuenta y quedará como riesgo oculto o

© Universidad Internacional de La Rioja (UNIR)

ignorado.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

Análisis de los riesgos

Por medio del análisis de riesgos se calificarán los riesgos identificados, obteniendo una cuantificación de sus consecuencias (si se realiza un análisis cuantitativo), o una ordenación de su importancia relativa (si se realiza un análisis cualitativo). Tanto si realizamos un análisis cuantitativo como si realizamos un análisis cualitativo, como resultado vamos a obtener una visión estructurada de los riesgos que nos va a permitir centrarnos en lo más importante.

Valoración de los riesgos

Es una valoración que va un paso más allá del análisis técnico, en la que se traducen las consecuencias a términos de negocio teniendo en cuenta factores de percepción, de estrategia y de política. Se toman decisiones respecto de qué riesgos van a ser objeto de tratamiento y de cuáles se aceptan, y cuáles no, de acuerdo con sus circunstancias.

Tratamiento de los riesgos

Se llevan a cabo acciones encaminadas a modificar la situación de riesgo. Es una actividad en la que se seleccionan e implementan las múltiples opciones de tratamiento que existen y que nos van a permitir modificar la situación de riesgo.

Comunicación y consulta

Es muy importante tener siempre en cuenta que los sistemas de información son el elemento clave que soporta las operaciones de la organización. Sería absurdo disponer de un sistema muy seguro, pero que dicha seguridad sea una rémora para la eficacia y la eficiencia de las operaciones de la organización, lo que impida que esta alcance sus objetivos. **Hay que buscar un equilibrio entre seguridad y productividad** y para lograr ese equilibrio hay que contar con la colaboración de:

© Universidad Internacional de La Rioja (UNIR)

- Los **usuarios,** cuyas necesidades deben ser tenidas en cuenta y a los que hay que informar para que colaboren activamente en la operación del sistema dentro de los parámetros de seguridad determinados por la dirección
- Los **proveedores externos,** a los que hay proporcionar instrucciones claras para poder exigirles tanto el cumplimiento de los niveles de servicio requeridos como la adecuada gestión de los incidentes de seguridad que pudieran acaecer
- Los **órganos de gobierno,** para establecer canales de comunicación que consoliden la confianza en que el sistema de información responderá de forma adecuada para atender a la misión de la organización y en que se hará frente a los incidentes de acuerdo con el plan previsto.

Seguimiento y revisión

Es importante tener siempre en cuenta que el análisis de riesgos es una actividad de despacho y que es imprescindible tener conocimiento de qué ocurre en la práctica y actuar en consecuencia, tanto reaccionando con rapidez a los incidentes como mejorando continuamente nuestro conocimiento del sistema y de su entorno para revisar y mejorar el proceso de gestión de riesgos dentro de un proceso de mejora continua.

Magerit es una metodología centrada en el 'activo', al cual define como:

> "Componente o funcionalidad de un sistema de información susceptible de ser atacado deliberada o accidentalmente con consecuencias para la organización. Incluye: información, datos, servicios, aplicaciones (software), equipos (hardware), comunicaciones, recursos administrativos, recursos físicos y recursos humanos" (Dirección General de Modernización Administrativa, Procedimientos e Impulso de la Administración Electrónica, 2012).

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

Para determinar el riesgo, Magerit establece una aproximación metódica:

- Determinar los **activos relevantes** para la organización, su interrelación y su valor en el sentido de qué **perjuicios** (costes) supondrían su degradación.
- Determinar a qué **amenazas** están expuestos aquellos activos.
- Determinar qué **salvaguardas** hay dispuestas y cuán eficaces son frente al riesgo.
- Estimar el '**impacto',** definido como el daño sobre el activo derivado de la materialización de la amenaza.
- Estimar el **'riesgo',** definido como el impacto ponderado con la tasa de ocurrencia (o expectativa de materialización) de la amenaza.

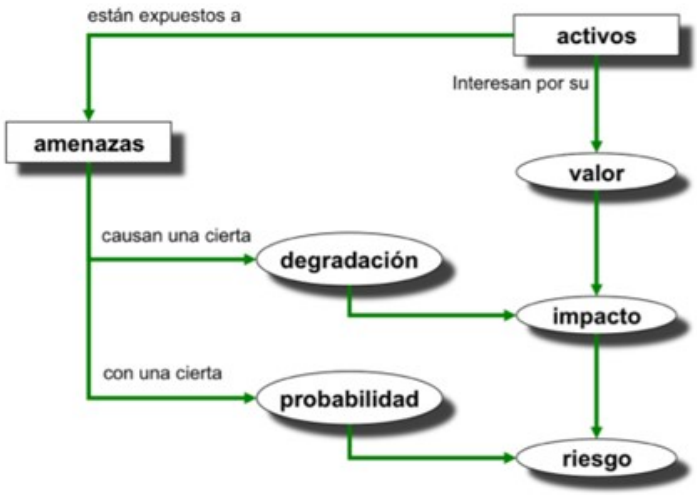


Figura 1. Elementos del análisis de riesgos potenciales. Fuente: Dirección General de Modernización Administrativa, Procedimientos e Impulso de la Administración Electrónica, 2012.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

Tareas para el análisis de los riesgos

Magerit establece que el análisis de los riesgos se realiza por medio de las siguientes **tareas** que se detallan a continuación:

© Universidad Internacional de La Rioja (UNIR)

MAR.1: caracterización de los activos

Esta actividad busca identificar los activos relevantes dentro del sistema a analizar, caracterizándolos por el tipo de activo, identificando las relaciones entre estos, determinando en qué dimensiones de seguridad son importantes y valorando esta importancia.

El resultado de esta actividad es el informe denominado "modelo de valor".

Subtareas:

- Tarea MAR.11: identificación de los activos.
- Tarea MAR.12: dependencias entre activos.
- Tarea MAR.13: valoración de los activos.

MAR.2: caracterización de las amenazas

Esta actividad busca identificar las amenazas relevantes sobre el sistema a analizar, caracterizándolas por las estimaciones de ocurrencia (probabilidad) y daño causado (degradación). El resultado de esta actividad es el informe denominado "mapa de riesgos".

Subtareas:

- Tarea MAR.21: identificación de las amenazas.
- Tarea MAR.22: valoración de las amenazas.

MAR.3: caracterización de las salvaguardas

Esta actividad busca identificar las salvaguardas desplegadas en el sistema a analizar, calificándolas por su eficacia frente a las amenazas que pretenden mitigar.

© Universidad Internacional de La Rioja (UNIR)

El resultado de esta actividad se concreta en varios informes:

- Declaración de aplicabilidad.
- Evaluación de salvaguardas.
- Insuficiencias (o vulnerabilidades del sistema de protección).

Subtareas:

- Tarea MAR.31: identificación de las salvaguardas pertinentes.
- Tarea MAR.32: valoración de las salvaguardas.

MAR.4: estimación del estado de riesgo

Esta actividad procesa todos los datos recopilados en las actividades anteriores para:

- Realizar un informe del estado de riesgo: estimación de impacto y riesgo.
- Realizar un informe de insuficiencias: deficiencias o debilidades en el sistema de salvaguardas.

Sub-tareas:

- Tarea MAR.41: estimación del impacto.
- Tarea MAR.42: estimación del riesgo.

Es frecuente que las tareas relacionadas con los activos (MAR.1) se realicen concurrentemente con las tareas relacionadas con las amenazas sobre dichos activos (MAR.2) e identificación de las salvaguardas actuales (MAR.3), simplemente porque suelen coincidir las personas y es difícil que el interlocutor no tienda de forma natural a tratar cada activo verticalmente, viendo todo lo que lo afecta antes de pasar al siguiente.

© Universidad Internacional de La Rioja (UNIR)

Toma de decisiones

Una vez conocidos los riesgos y los posibles impactos a los que está expuesto el sistema es necesario tomar una serie de decisiones al respecto que están condicionadas por los siguientes factores:

- El nivel de riesgo.
- La gravedad del impacto.
- Las obligaciones legales y reglamentarias.
- Las obligaciones contractuales.

Además, a la hora de tomar decisiones respecto al riesgo hay que tener en cuenta consideraciones adicionales sobre la disposición y la capacidad de la organización para asumir impactos de naturaleza intangible, como la pérdida de la reputación, que pueden influir negativamente en:

- En la imagen pública de la organización.
- En la relación con los propios empleados.
- En la relación con los proveedores.
- En la relación con los clientes o usuarios.
- En la relación con otras organizaciones y posibles socios de negocio.
- En la perdida de nuevas oportunidades de negocio.
- La obtención y mantenimiento de certificaciones y homologaciones.

© Universidad Internacional de La Rioja (UNIR)

Con base en las consideraciones anteriores, se deben calificar los riesgos significativos, determinando las acciones a tomar:

Tabla 1. Clasificación de los riesgos significativos y las acciones a tomar. Fuente: elaboración propia.

La opción de no tomar acción o aceptación del riesgo siempre es arriesgada y hay que tomarla de forma prudente y justificada. Las razones que pueden llevar a tomar la decisión de aceptar el riesgo son:

- El impacto residual es asumible.
- El riesgo residual es asumible.
- Cuando el coste de las salvaguardas es desproporcionado en relación con el impacto y riesgo residuales.

© Universidad Internacional de La Rioja (UNIR)

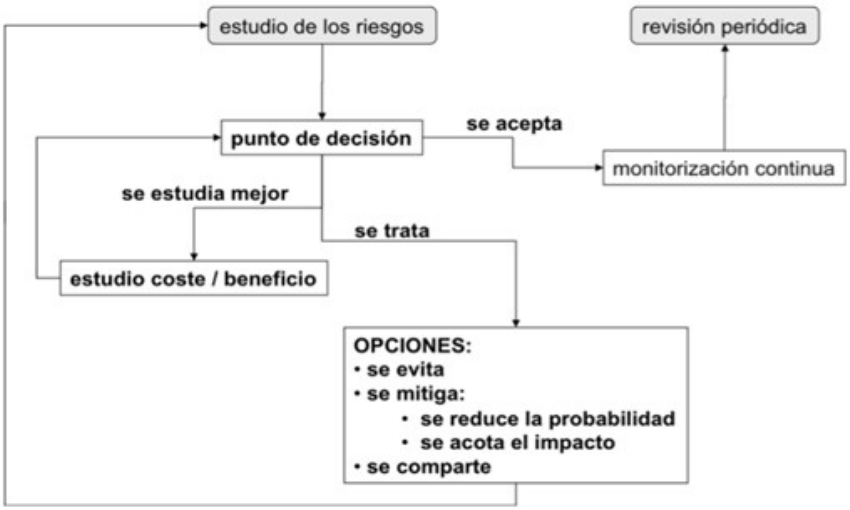


Figura 2. Decisiones de tratamiento de los riesgos. Fuente: Dirección General de Modernización Administrativa, Procedimientos e Impulso de la Administración Electrónica (2012).

La calificación de los riesgos tendrá consecuencias en las tareas subsiguientes, siendo un factor básico para establecer la prioridad relativa de las diferentes actuaciones.

© Universidad Internacional de La Rioja (UNIR)

8.3. ISO/IEC 27005:2018

ISO/IEC 27005:2011 Information technology —Security techniques— Information security risk management fue publicada en 2011, se apoya en los conceptos generales especificados en la ISO/IEC 27001 del ciclo PDCA, está diseñada para proporcionar las directrices en la ardua tarea del **enfoque basado en riesgos** y describe detalladamente la evaluación y tratamiento de riesgos. Esta norma no es una metodología de análisis de riesgos, sino que describe las fases recomendadas de análisis incluyendo el **establecimiento,** la **evaluación,** el **tratamiento,** la **aceptación,** la **comunicación,** la **monitorización y** la **revisión del riesgo.** No es una norma certificable y se engloba dentro de las normas que ayudan a la puesta en marcha del SGSI.

Tabla 2. Relación entre la ISO 27001 y la ISO 27005. Fuente: elaboración propia.

Dependiendo del alcance y los objetivos de la gestión del riesgo, se pueden aplicar diferentes enfoques y este, a su vez, puede ser diferente para cada iteración.

Debe seleccionarse o desarrollarse un enfoque de gestión del riesgo adecuado que aborde criterios básicos tales como:

- Criterios de evaluación de riesgos.
- Criterios de impacto.
- Criterios de aceptación de riesgos.

Además, la organización debe evaluar si dispone de los recursos necesarios para:

- Realizar la evaluación de riesgos y establecer un plan de tratamiento de riesgos.
- Definir e implementar políticas y procedimientos, incluyendo la implementación de

© Universidad Internacional de La Rioja (UNIR)

los controles seleccionados.

- Monitorizar los controles.
- Supervisar el proceso de gestión del riesgo de seguridad de la información.

Figura 3. Estructura General de Análisis de Riesgos. Fuente: adaptado de ISO 31000:2009 (2009).

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

Aproximaciones a la apreciación de riesgos

La ISO 27005 plantea dos aproximaciones en relación con la apreciación de riesgos de seguridad de la información: de alto nivel o detallada (ISO 27005, 2018).

Aproximación de alto nivel

Permite definir las prioridades y la cronología de las acciones. Por diversas razones, como puede ser la presupuestaria, puede que no sea posible implementar simultáneamente todos los controles necesarios y en el proceso de tratamiento del riesgo solo se puedan contemplar los riesgos más críticos, que pueden ser abordados a través del proceso de tratamiento de riesgo.

Además, puede ser prematuro iniciar una apreciación detallada de los riesgos si se prevé que su tratamiento no va a ser inmediato y se realizará dentro de uno o dos años. Para este caso, la apreciación de riesgos puede iniciarse con una apreciación de alto nivel de las consecuencias en lugar de comenzar con un análisis sistemático de los activos, de las amenazas, de las vulnerabilidades y de las consecuencias.

Otra razón para utilizar una aproximación de alto nivel es facilitar la sincronización de la apreciación de riesgos con otros planes relacionados con la gestión del cambio y la continuidad del negocio.

Características del proceso iterativo de apreciación de riesgos de alto nivel:

- Proporciona una visión más global de la organización y sus sistemas de información, considerando los aspectos tecnológicos como independientes de las cuestiones empresariales. De esta forma, el análisis del contexto se centra más en el entorno empresarial y operacional que en los elementos tecnológicos.
- Permite contemplar una lista más limitada de amenazas y vulnerabilidades agrupadas en dominios definidos o, para agilizar el proceso, puede centrarse en escenarios de riesgo o ataque en lugar de sus elementos.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

- Los riesgos contemplados en una apreciación de riesgo de alto nivel son, con frecuencia, riesgos más generales que los riesgos específicos identificados.
- No suele contemplar los detalles tecnológicos.
- Es más apropiada para proporcionar controles organizativos y no técnicos, así como aspectos de gestión de los controles o salvaguardas técnicos clave y comunes, como son las copias de seguridad y antivirus.

Las ventajas de una apreciación de riesgos con un enfoque de alto nivel son:

- Es probable que la utilización de un enfoque inicial sencillo facilite la aceptación del programa de apreciación de riesgos.
- Facilita la elaboración de una visión estratégica del programa de seguridad de la información de la organización.
- Ayuda a que los recursos, tanto económicos, como de otro tipo, se utilicen donde sean más útiles, y a priorizar la protección de los sistemas más críticos.

Un análisis de riesgos inicial de alto nivel es menos preciso y su única desventaja es que algunos procesos o sistemas pueden no ser identificados lo que requerirá una segunda apreciación de riesgo detallada.

Esto puede evitarse si hay información adecuada sobre todos los aspectos de la organización, su información y sus sistemas, incluida la información que se haya obtenido de la evaluación de incidentes de seguridad de la información.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

La apreciación del riesgo de alto nivel considera el valor de los activos de información de la organización y los riesgos a los que están expuestos desde un punto de vista de negocio.

Varios factores ayudan a determinar si la apreciación de alto nivel es adecuada para tratar los riesgos, estos factores pueden incluir lo siguiente:

- Los objetivos de negocio que necesitan varios activos de información para ser alcanzados.
- El grado de dependencia de los negocios de la organización de los activos de información.
- El nivel de inversión en cada activo de información, en términos de desarrollo, mantenimiento o sustitución del activo.
- Los activos de información, para los cuales la organización asigna directamente un valor.

Cuando se evalúan estos factores se facilita la decisión. Si los objetivos que dependen de un activo son extremadamente importantes para el desarrollo del negocio de una organización o si los activos están expuesto a un alto riesgo, debe realizarse una **segunda iteración,** con una apreciación detallada del riesgo para el activo de información en concreto (o parte de este).

Una regla general de aplicación es que, si la falta de seguridad de la información puede causar consecuencias adversas significativas para la organización, sus procesos de negocios o sus activos, entonces es necesaria una segunda iteración de la apreciación del riesgo de iteración, a un nivel más detallado, para identificar riesgos potenciales.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

Apreciación detallada del riesgo de seguridad de la información

El proceso detallado de apreciación del riesgo de seguridad de la información contempla la identificación y valoración en profundidad de los activos, la evaluación de las amenazas a la que están expuestas dichos activos y la evaluación de sus vulnerabilidades. Los resultados de estas actividades se utilizan para evaluar los riesgos y posteriormente identificar el tratamiento de riesgo adecuado.

La apreciación detallada del riesgo suele requerir mucho **tiempo, esfuerzo y experiencia,** por lo que puede ser más **adecuado para sistemas de información de alto riesgo.**

La última etapa de la apreciación detallada de los riesgos de seguridad de la información consiste en evaluar los riesgos generales.

Las consecuencias pueden evaluarse de varias maneras, incluyendo el uso de métodos de valoración cuantitativos, cuantitativos o de una combinación de ambos.

Para evaluar la probabilidad de materialización de una amenaza, debe establecerse el marco temporal sobre el cual el activo tiene valor o es necesario proteger. La probabilidad de que se materialice una amenaza específica depende de:

- El atractivo del bien o el posible impacto.
- La facilidad de obtención de beneficio por parte del atacante de la explotación de la vulnerabilidad.
- Las capacidades técnicas del atacante.
- La facilidad de explotación de la vulnerabilidad.

Muchos métodos hacen uso de tablas y combinan medidas subjetivas y empíricas. Es importante que la organización utilice un método con el que se sienta cómoda, en el que tenga confianza y que produzca resultados repetibles.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

© Universidad Internacional de La Rioja (UNIR)

8.4. NIST 800-30 Rev. 1

Las organizaciones, independientemente de su tamaño y del sector al que pertenezcan, tienen una gran dependencia de la tecnología de la información y los sistemas de información para desarrollar sus operaciones y así alcanzar con éxito sus objetivos de negocio.

Existen sistemas de información muy diversos que van desde redes de oficinas, sistemas financieros y de personal hasta sistemas muy especializados, como pueden ser: sistemas de control industrial o de procesos, sistemas de armas, sistemas de telecomunicaciones y sistemas de control ambiental.

Los sistemas de información están expuestos a graves amenazas que pueden tener efectos adversos en las operaciones y en los activos de la organización. Individuos, otras organizaciones u otros países pueden explotar las vulnerabilidades, tanto conocidas como desconocidas, de dichos sistemas, para comprometer la confidencialidad, integridad o disponibilidad de la información que procesan, almacenan o transmiten.

Las amenazas a los sistemas de información pueden ser de carácter intencionado, errores humanos o mecánicos, fallos estructurales, medioambientales e incluso una combinación de diversos tipos.

Es necesario que los gerentes de todos los niveles de la organización entiendan sus responsabilidades y sean conscientes de la necesidad de gestionar el riesgo de seguridad de la información, es decir, el riesgo asociado con la operación y el uso de los sistemas de información que respaldan el funcionamiento de las operaciones de la organización.

© Universidad Internacional de La Rioja (UNIR)

Proceso de Gestión del Riesgo

NIST 800-39 Gestión de riesgos de seguridad de la información: vista de organización, misión y sistema de información.

La evaluación de riesgos es un proceso holístico que forma parte del proceso de gestión de riesgos de la organización.

De acuerdo con la NIST Special Publication 800-39, los procesos de gestión de riesgos incluyen (National Institute of Standards and Technology, 2011):

- El marco de referencia del riesgo.
- La evaluación de riesgos.
- La respuesta a los riesgos.
- El seguimiento de los riesgos.

Figura 4. Procesos de gestión de riesgos. Fuente: elaboración propia.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

El marco de referencia es el **primer componente** de la gestión de riesgos, en el que la organización establece el contexto del riesgo, es decir, se describe el entorno en el que se van a tomar las decisiones basadas en el riesgo.

El **propósito** del marco de referencia es elaborar una estrategia de gestión de riesgos que establezca cómo la organización va a analizar, responder y monitorizar el riesgo.

La estrategia de gestión de riesgos establece una base para la gestión de riesgos y establece los criterios para la toma de decisiones basadas en riesgos de la organización.

El **segundo componente** de la gestión de riesgos, la evaluación de riesgos, aborda cómo la organización evalúa el riesgo de acuerdo con el contexto establecido en el marco de referencia del riesgo.

El **propósito** de la evaluación de riesgos es identificar:

- Las amenazas a la que está expuesta la organización.
- Las vulnerabilidades internas y externas a la organización.
- El daño o impacto que pudiera sufrir la organización, dado el potencial de las amenazas que pudieran explotar las vulnerabilidades.
- La probabilidad de que se materialice la amenaza y se produzca un impacto.

El resultado de la evaluación de riesgos es una valoración del riesgo, típicamente, una función del impacto y la probabilidad.

El **tercer componente** de la gestión de riesgos es la respuesta al riesgo de la organización, que se realiza una vez que el valor del riesgo se determina en función de los resultados de la evaluación de riesgos.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

El **propósito** de la respuesta al riesgo es proporcionar una respuesta consistente al riesgo de toda la organización de acuerdo con el marco de referencia del riesgo:

- Desarrollar alternativas para responder al riesgo.
- Evaluar las alternativas para responder al riesgo.
- Determinar las respuestas apropiadas, consistentes con la tolerancia al riesgo de la organización.
- Implementar las respuestas al riesgo seleccionadas.

El **cuarto componente** de la gestión de riesgos, la supervisión del riesgo, aborda cómo la organización monitoriza el riesgo a lo largo del tiempo.

El **propósito** de la supervisión de riesgos es:

- Valorar de forma continua la efectividad de las respuestas al riesgo.
- Identificar los cambios de los sistemas de información que impactan el riesgo organizacional y de los entornos en los que operan los sistemas.
- Verificar que se han implementado las respuestas al riesgo planificadas y que los requisitos de seguridad de la información se derivan de las necesidades de la organización y del cumplimiento de las obligaciones legales y contractuales.

Evaluación de riesgos

Profundizando en el componente de Evaluación de riesgos, la **NIST SP 800-30 Rev.1** proporciona un modelo de proceso metódico para la evaluación de riesgos con los siguientes pasos:

- Preparación de la evaluación de riesgos.
- Ejecución de la evaluación de riesgos.

© Universidad Internacional de La Rioja (UNIR)

- Comunicación de los resultados de la evaluación de riesgos al personal clave de la organización.
- Mantenimiento de la evaluación de riesgos a lo largo del tiempo.

Las evaluaciones de riesgos contemplan los posibles riesgos para las operaciones y los activos de la organización, derivados de la operación y el uso de los sistemas de información y de la información que procesan, almacenan y transmiten.

Las evaluaciones de riesgos dan soporte a una amplia variedad de decisiones y actividades basadas en riesgos por parte la organización, entre las que se incluyen:

- Desarrollo de una arquitectura de seguridad de la información.
- Definición de los requisitos de interconexión para los sistemas de información.
- Diseño de soluciones de seguridad para sistemas de información y entornos de operación.
- Autorización para operar sistemas de información.
- Implementación de soluciones de seguridad.
- Operación y mantenimiento de soluciones de seguridad.

Enfoques de la evaluación de riesgos

El riesgo y sus factores contribuyentes se pueden evaluar de varias maneras: el enfoque **cuantitativo,** el **cualitativo o** el **semicuantitativo.** Cada uno de estos enfoques tiene ventajas y desventajas respecto al resto. A la hora de realizar una evaluación de riesgos se puede adoptar un único enfoque o una combinación de estos en función de las necesidades y de la cultura de la organización.

Las **evaluaciones cuantitativas** utilizan un conjunto de métodos, principios o reglas para evaluar el riesgo en función de **valores numéricos,** donde los significados y la

© Universidad Internacional de La Rioja (UNIR)

proporcionalidad de los valores se mantienen dentro y fuera del contexto de la evaluación. Este tipo de evaluación apoya de una manera más efectiva los análisis de coste/beneficio de las posibles respuestas al riesgo que los otros tipos de evaluación.

Sin embargo, el significado de los valores numéricos de una evaluación cuantitativa puede que no sea siempre claro el resultado, lo que requerirá una **interpretación** y explicación.

Adicionalmente, el rigor de la cuantificación disminuye significativamente cuando valoraciones subjetivas se ocultan dentro de evaluaciones cuantitativas o cuando existe una **incertidumbre** significativamente relevante a la hora de determinar la valoración numérica.

Los beneficios de las evaluaciones cuantitativas pueden, en algunos casos, ser compensados por los costes derivados del tiempo y esfuerzo de los expertos y el posible despliegue y uso de herramientas necesarias para hacer tales evaluaciones.

A diferencia de las evaluaciones cuantitativas, las evaluaciones cualitativas utilizan un conjunto de métodos, principios o reglas para evaluar el riesgo en función de categorías o niveles no numéricos, como pueden ser: muy bajo, bajo, moderado, alto, muy alto.

La **evaluación cualitativa** es de gran ayuda a la hora de la **comunicación de los resultados** de la evaluación del riesgo a los responsables de la toma de decisiones. Sin embargo, el **rango de valores** en las evaluaciones cualitativas es comparativamente **pequeño** en la mayoría de los casos, lo que supone una dificultad a la hora de priorizar los riesgos o la de efectuar comparaciones entre los diferentes riesgos reportados.

Adicionalmente, a menos que cada valor esté perfectamente definido o se le caracterice por medio de ejemplos significativos, se podrían producir resultados de

© Universidad Internacional de La Rioja (UNIR)

evaluación de riesgos con diferencias significativas, por parte de diferentes expertos que habitualmente confían en sus experiencias individuales.

Las **evaluaciones semicuantitativas** utilizan un conjunto de métodos, principios o reglas para evaluar el riesgo que utilizan agrupaciones, escalas o valores numéricos cuyos rangos y significados no se mantienen en otros contextos.

Pueden combinar los beneficios de las evaluaciones cuantitativas y cualitativas.

Las agrupaciones y escalas se traducen fácilmente en términos cualitativos que ayudan a la comunicación de los resultados de la evaluación del riesgo a los responsables de la toma de decisiones las comunicaciones de riesgos para los tomadores de decisiones.

El papel del juicio experto en la asignación de valores es más evidente que en un enfoque puramente cuantitativo.

Además, si las escalas o agrupaciones proporcionan suficiente granularidad, la priorización relativa entre los resultados está mejor respaldada que en un enfoque puramente cualitativo.

Al igual que en un enfoque cuantitativo, **el rigor disminuye significativamente cuando valoraciones subjetivas se ocultan dentro de evaluaciones cuantitativas** o cuando existe una incertidumbre significativamente relevante a la hora de determinar el valor.

Aproximaciones al análisis de riesgos

Las aproximaciones al análisis de riesgos difieren con respecto a la orientación o el punto de partida de la evaluación de riesgos, el nivel de detalle en la evaluación y de cómo se tratan los riesgos debidos a escenarios de amenazas similares.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

Las aproximaciones pueden ser:

- Orientada a amenazas.
- Orientada al impacto en el activo.
- Orientada a la vulnerabilidad.

Una **aproximación orientada a la amenaza** comienza con la identificación de las fuentes y los eventos de las amenazas y se centra en el desarrollo de los escenarios de la amenaza. Las **vulnerabilidades** se identifican dentro el **contexto** de las amenazas y los **impactos** se identifican en función de la **intención del atacante.**

Una aproximación **orientada al impacto** en los activos comienza con la identificación de los impactos o consecuencias sobre los activos críticos que pueden ser una fuente de preocupación, utilizando para ello los **objetivos** de negocio **de la organización** o **los resultados de un análisis de impacto** en el negocio, identificando los eventos de amenazas que nos podrían llevar a determinar los orígenes de amenazas.

Una aproximación **orientada a la vulnerabilidad** se inicia identificando el conjunto de **condiciones preexistentes, debilidades y deficiencias de los sistemas de información** de la organización o los entornos en los que operan los sistemas, que pueden ser **explotables** por un atacante, e identifica las amenazas y condiciones necesarias para explotar esas vulnerabilidades.

Cada aproximación al análisis tiene en cuenta los mismos factores de riesgo y, por lo tanto, conlleva el mismo conjunto de actividades de evaluación de riesgos, aunque en un orden diferente.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

Las diferencias en el punto de partida de la evaluación de riesgos pueden sesgar los resultados, lo que puede provocar que algunos riesgos no se identifiquen. Por lo tanto, la identificación de riesgos desde una segunda aproximación puede mejorar el rigor y la efectividad del análisis.

Adicionalmente, se pueden aplicar técnicas de análisis más rigurosas, como pueden ser los análisis basados en gráficos, para proporcionar una forma efectiva de explicar las relaciones de muchos a muchos entre:

- **Fuentes de amenazas y eventos de amenazas:** un solo evento de amenaza puede ser causado por múltiples fuentes de amenaza y una sola fuente de amenaza puede causar múltiples eventos de amenaza.
- **Eventos de amenaza y vulnerabilidades:** un solo evento de amenaza puede explotar múltiples vulnerabilidades y una sola vulnerabilidad puede ser explotada por múltiples eventos de amenaza.
- **Eventos de amenaza e impactos / activos:** un solo evento de amenaza puede afectar múltiples activos o tener múltiples impactos y un solo activo puede verse afectado por múltiples eventos de amenaza.

Proceso de evaluación del riesgo

El proceso de evaluación de riesgos, como se indicaba antes, se compone de cuatro fases:

- Preparación.
- Ejecución.
- Comunicación de resultados.
- Mantenimiento.

© Universidad Internacional de La Rioja (UNIR)

Y cada fase se divide en distintas tareas tal como se muestra en el siguiente esquema:

Figura 5. Proceso de evaluación del riesgo. Fuente: elaboración propia.

Fase 1: preparación para la evaluación de riesgos

La primera fase del proceso de evaluación de riesgos es la preparación para la evaluación. El objetivo de esta fase es establecer el contexto para la evaluación de riesgos. Este contexto se establece con base en el marco de referencia del proceso de gestión de riesgos.

El marco de referencia del riesgo establece los criterios de la organización con respecto a políticas y requisitos para realizar evaluaciones de riesgo, metodologías de evaluación específicas que se emplearán, procedimientos para seleccionar los factores de riesgo a considerar, alcance de las evaluaciones, rigor de análisis, grado de formalidad y requisitos que van a permitir realizar evaluaciones de riesgo consistentes y repetibles en toda la organización.

La preparación para la evaluación de riesgos incluye las siguientes **tareas:**

- Identificar el propósito de la evaluación.
- Identificar el alcance de la evaluación.
- Identificar los supuestos y limitaciones asociados con la evaluación.
- Identificar las fuentes de información que se utilizarán como entrada para la evaluación.
- Identificar el modelo de riesgo y los enfoques analíticos que se emplearán durante la evaluación.

© Universidad Internacional de La Rioja (UNIR)

Fase 2: ejecución de la evaluación

La ejecución de la evaluación de riesgos incluye las siguientes **tareas:**

- Identificar los orígenes de la amenaza.
- Identificar los eventos de amenaza.
- Identificar vulnerabilidades y condiciones preexistentes.
- Estimar la probabilidad de ocurrencia.
- Estimar el impacto.
- Estimar el riesgo.

© Universidad Internacional de La Rioja (UNIR)

Para estimar la probabilidad de ocurrencia de una materialización de una amenaza hay que considerar:

- Los orígenes de la amenaza.
- Las vulnerabilidades y condiciones preexistentes.
- Los controles o medidas de seguridad existentes.

Fase 3: comunicación de resultados

La tercera fase del proceso de evaluación de riesgos es comunicar los resultados de la evaluación y compartir la información relacionada con el riesgo. El objetivo de esta fase es garantizar que los responsables de la toma de decisiones en toda la organización tengan la información necesaria relativa al riesgo.

La comunicación y el intercambio de información constan de las siguientes tareas específicas:

- Comunicar los resultados de la evaluación de riesgos.
- Compartir información obtenida en la ejecución de la evaluación de riesgos para apoyar otras actividades de gestión de riesgos.

Fase 4: mantenimiento de la evaluación

La cuarta fase del proceso de evaluación de riesgos es el mantenimiento de la evaluación. El objetivo de esta fase es mantener actualizado el conocimiento específico del riesgo. Los resultados de las evaluaciones de riesgos proporcionan información para la toma de decisiones de gestión de riesgos y guían las respuestas a los riesgos. Con el objetivo de dar soporte a la revisión continua de las decisiones relativas a la gestión de riesgos es necesario efectuar un mantenimiento de riesgos para incorporar cualquier cambio detectado a través de la monitorización.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

La monitorización proporciona a la organización los medios para:

- Determinar la efectividad de las respuestas al riesgo.
- Identificar los cambios que afectan el riesgo de los sistemas de información de la organización y los entornos en los que operan dichos sistemas.
- Verificar el cumplimiento.

El mantenimiento de la evaluación de riesgos incluye las siguientes **tareas** específicas:

- Monitorización continua de los factores de riesgo identificados en la evaluación de riesgo, para detectar y comprender dichos cambios
- Actualización de la evaluación de riesgos de forma que refleje los cambios detectados en la monitorización.

© Universidad Internacional de La Rioja (UNIR)

8.5. Referencias bibliográficas

Dirección General de Modernización Administrativa, Procedimientos e Impulso de la Administración Electrónica. (2012). *MAGERIT – versión 3.0. Metodología de Análisis y Gestión de Riesgos de los Sistemas de Información. Libro I: Método.* Ministerio de Hacienda y Administraciones Públicas. https://administracionelectronica.gob.es/pae_Home/pae_Documentacion/pae_Metodolog/pae_Magerit.html

Dirección General de Modernización Administrativa, Procedimientos e Impulso de la Administración Electrónica. (2012). *MAGERIT – versión 3.0. Metodología de Análisis y Gestión de Riesgos de los Sistemas de Información. Libro II: Catálogo de Elementos.* Ministerio de Hacienda y Administraciones Públicas. https://administracionelectronica.gob.es/pae_Home/pae_Documentacion/pae_Metodolog/pae_Magerit.html

Dirección General de Modernización Administrativa, Procedimientos e Impulso de la Administración Electrónica. (2012). *MAGERIT – versión 3.0. Metodología de Análisis y Gestión de Riesgos de los Sistemas de Información. Libro III: Guía de Técnicas.* Ministerio de Hacienda y Administraciones Públicas. https://administracionelectronica.gob.es/pae_Home/pae_Documentacion/pae_Metodolog/pae_Magerit.html

International Organization for Standardization. (2009). *Risk management — Principles and guidelines* (estándar ISO 31000:2009). https://www.iso.org/standard/43170.html

International Organization for Standardization. (2018). Information security management (estándar ISO 27001:2018). https://www.iso.org/standard/43170.html

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

International Organization for Standardization. (2018). *Information technology — Security techniques — Information security risk management* (estándar ISO/IEC 27005:2018). https://www.iso.org/standard/73906.html

National Institute of Standards and Technology. (2011). NIST Special Publication 800-30. https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-30r1.pdf

National Institute of Standards and Technology. (2011). *NIST Special Publication 800-39.* https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-39.pdf

© Universidad Internacional de La Rioja (UNIR)

Análisis de Magerit y PILAR

Santiago Bartolomé, I. (2019). *Análisis de Magerit y PILAR* [Tesis Fin de Grado]. Universidad de Valladolid. http://uvadoc.uva.es/handle/10324/37736

El principal objetivo de este Trabajo Fin de Grado (TFG) es el análisis de Magerit, una metodología sistemática para el análisis y gestión de los riesgos que derivan del uso de la información, y Pilar, que consiste en una herramienta diseñada para analizar los riesgos de un sistema siguiendo la metodología de Magerit, con la intención de mejorarlas añadiendo propuestas, cambiando, modificando o eliminando procesos ya implantados y asegurando el cumplimiento de todas las normas requeridas en el ámbito de la seguridad de la información.

© Universidad Internacional de La Rioja (UNIR)

Artículo de revisión de Metodologías de Análisis de Riesgos de la Información, enfocado a Pymes

Ocampo, M. (2017). *Artículo de revisión de Metodologías de Análisis de Riesgos de la Información, enfocado a Pymes* [Especialización en Gerencia Estratégica de Tecnologías de la Información]. Universidad Santiago de Cali. https://repository.usc.edu.co/bitstream/handle/20.500.12421/2942/ARTICULO%20DE%20REVISI%C3%92N.pdf?sequence=2

Este articulo explora diferentes puntos de vista de cómo identificar los riesgos que presenta la información de las compañías. Hoy en día hay diferentes puntos de vista al respecto, pero la gran mayoría están diseñados para grandes compañías que a su vez cuentan con grandes estructuras, lo que hace que sea muy compleja la implementación de estas en la mayoría de las empresas colombianas.

Esta revisión pretende unificar diferentes puntos de vista y sintetizar en una forma ágil y sencilla dichas metodologías que le generen valor a las pymes en el análisis y gestión de los riesgos asociados a su información, no solo en aspectos que tengan que ver con la ciberseguridad sino también con el manejo de información física y el conocimiento que puede hacer la diferencia entre una y otra compañía que compitan por el mismo mercado.

© Universidad Internacional de La Rioja (UNIR)

Gestión del riesgo de TI con base en la norma ISO 27005:2011, adaptando la metodología NIS SP 800-30

Mora, L. J. y Chavarro Flores, F. A. (2016). *Gestión del riesgo de TI con base en la norma ISO 27005:2011, adaptando la metodología NIS SP 800-30. Para el caso de estudio propuesto* [Trabajo de Grado]. Universidad del Cauca. http://repositorio.unicauca.edu.co:8080/bitstream/handle/123456789/1530/GESTI%C3%93N%20DEL%20RIESGO%20DE%20SI%20%20CON%20BASE%20EN%20LA%20NORMA%20ISO%20IEC%2027005%202011%2C%20ADAPTANDO%20LA%20METODOLOG%C3%8DA%20NIST%20SP%20800-30.pdf?sequence=1&isAllowed=y

Este trabajo consiste en desarrollar la fase del plan de un Sistema de Gestión de Seguridad de la Información basado en la norma NTC ISO/IEC 27001:2013 siguiendo la guía de implementación GTC ISO/IEX 27003:2012, aplicando la metodología NIST SP 800-30 para realizar la etapa de valoración de riesgos y finalmente definiendo las opciones del tratamiento de los riesgos.

© Universidad Internacional de La Rioja (UNIR)

Gestión de riesgos de seguridad. (2009). Análisis de modelos según NIST SP 800-30" y la norma ISO/IEC 27005:2008

Avellaneda, O. y Rondon, M. (2009, septiembre). Gestión de riesgos de seguridad. *Info@CITEL*, (63). http://www.oas.org/en/citel/infocitel/2009/septiembre/seguridad_e.asp

Esta contribución presenta una descripción detallada del proceso por medio del cual puede llevarse a cabo la gestión de riesgos. Se examinan dos modelos: la *Guía de gestión de riesgos de los sistemas de tecnología de la información - NIST SP 800-30* y la norma ISO/IEC 27005:2008, *Tecnología de la información – Técnicas de seguridad – Gestión de riesgos de la seguridad de la información.*

© Universidad Internacional de La Rioja (UNIR)

Gestión de riesgos. Magerit

Rodríguez, J. M. y Peralta, I. (2013). *Gestión de riesgos. Magerit.* tiThink. https://www.tithink.com/publicacion/Magerit.pdf

El análisis y gestión de los riesgos es un aspecto clave del Real Decreto 3/2010 del 8 de enero, por el que se regula el Esquema Nacional de Seguridad en el ámbito de la Administración Electrónica, que tiene la finalidad de poder dar satisfacción al principio de proporcionalidad en el cumplimiento de los principios básicos y requisitos mínimos para la protección adecuada de la información.

Magerit es un instrumento para facilitar la implantación y aplicación del Esquema Nacional de Seguridad proporcionando los principios básicos y requisitos mínimos para la protección adecuada de la información.

En este documento, se resaltan los aspectos fundamentales del método Magerit.

© Universidad Internacional de La Rioja (UNIR)

1. Magerit es una metodología:

A. Centrada en el activo.

B. Centrada en el riesgo.

C. Centrada en la vulnerabilidad.

D. Centrada en la amenaza.

2. Según la metodología Magerit las decisiones respecto al riesgo no están condicionadas por:

A. El nivel de riesgo.

B. El origen de amenaza.

C. Las obligaciones contractuales.

D. La gravedad del impacto.

3. De acuerdo con la ISO 27005, ¿cuál de las siguientes opciones no es una característica de la apreciación de riesgos de alto nivel.

A. Permite contemplar una lista más limitada de amenazas.

B. No es la más apropiada para proporcionar controles organizativos.

C. Proporciona una visión más global de la organización.

D. Puede centrarse en escenarios de riesgo.

4. De acuerdo con la ISO 27005, la probabilidad de que se materialice una amenaza específica no depende de:

A. El atractivo del bien o el posible impacto.

B. La facilidad de obtención de beneficios por parte del atacante.

C. El número de activos.

D. La facilidad de explotación de la vulnerabilidad.

© Universidad Internacional de La Rioja (UNIR)

5. Según la metodología Magerit, ¿cuál de las siguientes no es una técnica especifica?

A. Análisis algorítmico.

B. Análisis mediante tablas.

C. Valoración Delphi.

D. Arboles de ataque.

6. De acuerdo con la ISO 27005, el proceso detallado de apreciación del riesgo de seguridad de la información contempla:

A. La identificación y valoración en profundidad de los activos.

B. La identificación de los activos y de las salvaguardas.

C. La evaluación de activos y amenazas.

D. La evaluación de amenazas y salvaguardas.

7. Según la norma NIST 800-30 Rev. 1, los procesos de gestión de riesgos incluyen:

A. El marco de referencia del riesgo, la evaluación, la respuesta y el seguimiento de los riesgos.

B. El marco de referencia del riesgo, la valoración, la respuesta y el seguimiento de los riesgos.

C. El marco de referencia del riesgo, la valoración, el tratamiento y el seguimiento de los riesgos.

D. El marco de referencia del riesgo, la evaluación, el tratamiento y el seguimiento de los riesgos.

© Universidad Internacional de La Rioja (UNIR)

8. Según la norma NIST 800-30 Rev. 1, el proceso de evaluación de riesgos se compone de las siguientes fases:

A. Preparación, ejecución, revisión y comunicación de resultados.

B. Preparación, valoración, comunicación de resultados y mantenimiento.

C. Preparación, ejecución, comunicación de resultados y mantenimiento.

D. Preparación, valoración, revisión y comunicación de resultados.

9. Según la norma NIST 800-30 Rev. 1, para estimar la probabilidad de ocurrencia de una materialización de una amenaza no hay que considerar:

A. Los orígenes de la amenaza.

B. La facilidad de obtención de beneficio por parte del atacante.

C. Las vulnerabilidades y condiciones preexistentes.

D. Los controles o medidas de seguridad existentes.

10. Según la norma NIST 800-30 Rev. 1, las aproximaciones al análisis de riesgos pueden estar orientadas a:

A. Las amenazas, al impacto en el activo o a probabilidad.

B. Las amenazas, al activo o a la vulnerabilidad.

C. Las amenazas, al riesgo o al impacto en el activo.

D. Las amenazas, al impacto en el activo o a la vulnerabilidad.

© Universidad Internacional de La Rioja (UNIR)